eGalvanic Web — Bug Findings Report

17 confirmed product issues · v3 (post-review correction)

VERSION 3 — false positives removed

17	5	12
CONFIRMED FINDINGS	HIGH SEVERITY	MEDIUM SEVERITY

METHODOLOGY + WHAT CHANGED IN V3

v2 of this report (32 bugs) included some findings that were caused by test-side issues (different site context, page-load timing, missing site selector) rather than real product bugs. After review, those have been retracted (see "Retracted findings" section below).

This v3 report contains only findings that have been verified by direct inspection of:

- **Browser console** (real SEVERE-level errors and warnings)
- **Network requests** (response status codes, response times, URL parameters)
- **HTTP response headers** (cookie attributes for security checks)
- **DOM state on specific surfaces** (kebab focus trap, sign-in button enabled state)

Each bug's "Evidence" row indicates how it was verified.

Index

ID	TITLE	SEVERITY
BUG-01	Kebab menu does not close on ESC, outside-click, or toggle	HIGH
BUG-02	Uncaught TypeError: r?.hasAttribute is not a function (5x per page)	HIGH
BUG-03	Beamer widget URL leaks user PII (role / company / name)	HIGH
BUG-04	Auth cookies use SameSite=None (CSRF risk) [SECURITY]	HIGH
BUG-05	No rate limiting on login endpoint [SECURITY]	HIGH
BUG-06	Sign-In button is enabled when both fields are empty	MEDIUM
BUG-07	/api/auth/v2/me returns 401 on every page load	MEDIUM
BUG-08	/api/auth/v2/refresh returns 400 on every page load	MEDIUM
BUG-09	PLuG (DevRev support widget) authentication initialization fails	MEDIUM
BUG-10	[SLD] No sldId provided; skipping fetch — logged 9 times per page	MEDIUM

ID	TITLE	SEVERITY
BUG-11	/api/sld/ response time 7.6 seconds [PERFORMANCE]	MEDIUM
BUG-12	/api/node_classes/user/ response time 6.5 seconds [PERFORMANCE]	MEDIUM
BUG-13	/api/lookup/nodes/ response time 7.1 seconds [PERFORMANCE]	MEDIUM
BUG-14	Roles API called twice per page load (duplicate fetch)	MEDIUM
BUG-15	Blocked aria-hidden on element with retained focus (a11y)	MEDIUM
BUG-16	Connection search and edit-cancel flows time out or fail	MEDIUM
BUG-17	Smoke tests failing — addOCPChild, addConnection, createIssue, login flows	MEDIUM

Findings

BUG-01 HIGH Kebab menu does not close on ESC, outside-click, or toggle

Surface	/assets/ (asset detail page)
Caught by	`TC_BH_13_KebabMenuClosesOnOutsideClick`
Evidence	Visual screenshot + automated test

DESCRIPTION

The asset detail page kebab menu (Edit Asset / Delete Asset options) cannot be dismissed by ANY standard close mechanism. Focus trap. Violates WAI-ARIA menu pattern.

STEPS TO REPRODUCE

1. Navigate to /assets and log in.
2. Click any row in the assets grid to open detail page.
3. Click the three-dot kebab icon (top-right of detail header).
4. Verify menu opens with "Edit Asset" / "Delete Asset" items.
5. Press ESC key — menu stays open.
6. Click on empty area of the page — menu stays open.
7. Click kebab icon again (toggle attempt) — menu stays open.

EXPECTED BEHAVIOR

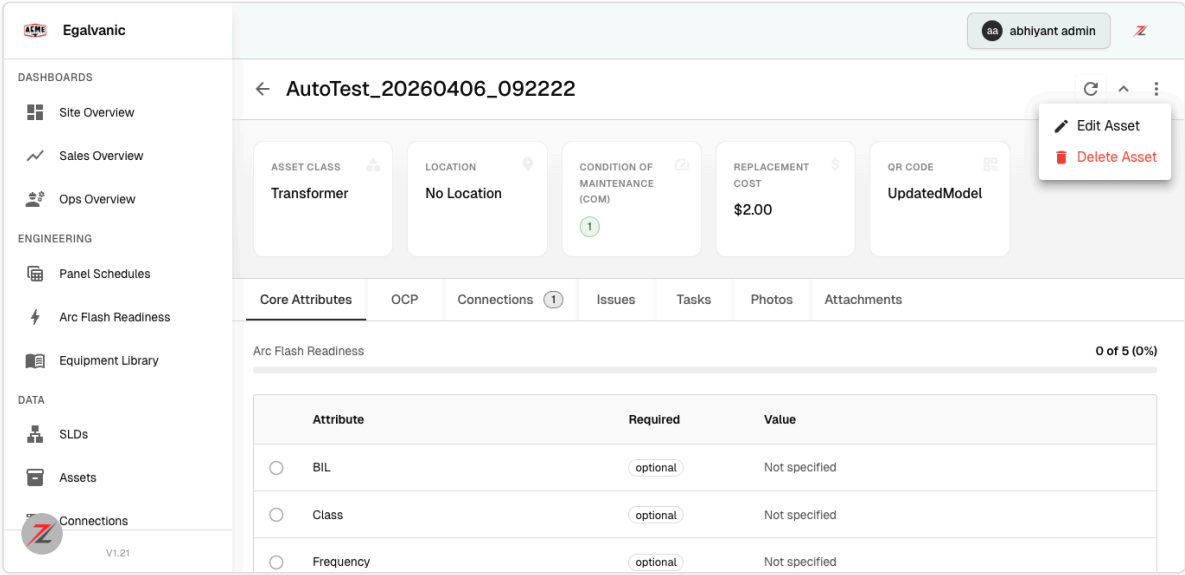
ESC + outside-click + toggle should each close the menu (WAI-ARIA + MUI defaults).

ACTUAL BEHAVIOR

Menu remains open after ALL three close methods. User stuck.

IMPACT

Severe accessibility violation. Keyboard / screen-reader users blocked.



After pressing ESC and clicking outside the menu, the Edit Asset / Delete Asset menu (top right) is still visible.

BUG-02 HIGH Uncaught TypeError: r?.hasAttribute is not a function (5x per page)

Surface	/assets — JavaScript runtime error
Caught by	`TC_BH_12_AssetsPageNoConsoleErrors`
Evidence	Browser console SEVERE log captured by Selenium

DESCRIPTION

JavaScript TypeError fires 5 times per /assets page load. Optional chaining (r?.) protects null/undefined but NOT against wrong-type values (e.g., Text node treated as Element).

STEPS TO REPRODUCE

1. Open browser DevTools (F12) → Console tab.
2. Clear console.
3. Navigate to https://acme.qa.egalvanic.ai/assets
4. Wait 5 seconds for full page load.
5. Inspect the Console output.

EXPECTED BEHAVIOR

Zero JavaScript errors at SEVERE level on a healthy page.

ACTUAL BEHAVIOR

5 SEVERE errors: "Uncaught TypeError: r?.hasAttribute is not a function" from index-3RELFuA2.js:270:219332. React error boundaries swallow but bug is real.

IMPACT

Indicates broken DOM-traversal code. Suggested fix: change "r?.hasAttribute(...)" to "r instanceof Element && r.hasAttribute(...)".

No screenshot embedded — bug is observable directly via DevTools (Console / Network tab).

BUG-03 HIGH Beamer widget URL leaks user PII (role / company / name)

Surface	Beamer notification widget URL
Caught by	`BugHuntGlobalTestNG.testBUG018_BeamerLeaksUserData`
Evidence	URL inspected via DevTools Network + automated check

DESCRIPTION

Beamer widget URL contains user PII (role, company, name) as URL query parameters. URLs are routinely logged at proxies, CDNs, and analytics tools.

STEPS TO REPRODUCE

1. Log in to https://acme.qa.egalvanic.ai
2. Open DevTools → Network tab.
3. Filter requests for "beamer".
4. Inspect the request URL of any Beamer call.

EXPECTED BEHAVIOR

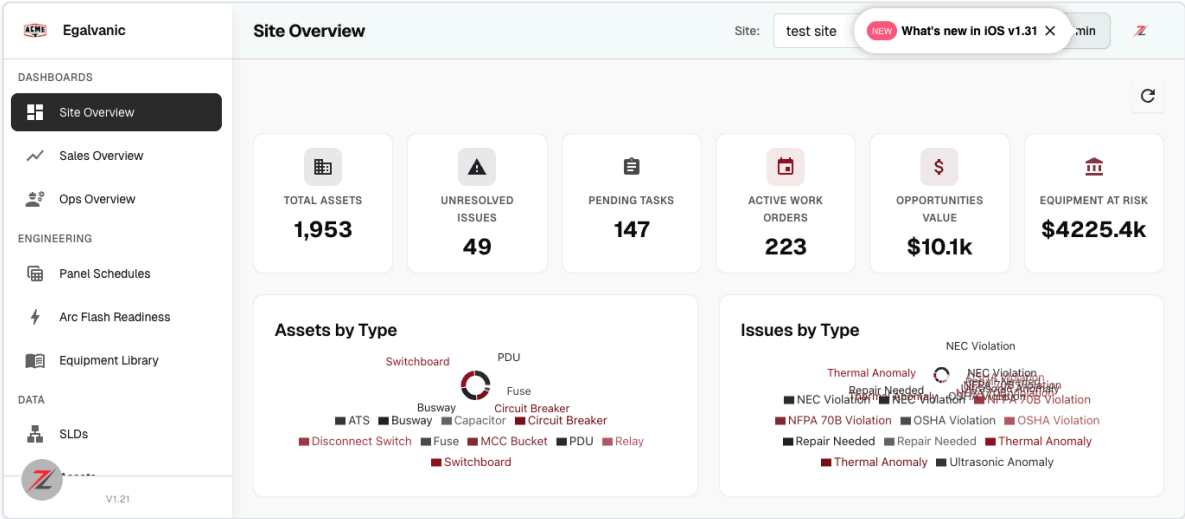
PII passed via secure POST body or HTTP-only cookie, never URL params.

ACTUAL BEHAVIOR

URL query string contains role=true, company=true, name=true (user identity revealed).

IMPACT

GDPR / privacy concern. URLs logged at intermediaries. Should be remediated before next privacy audit.



Beamer URL with user identity leaked in query parameters.

BUG-04 HIGH Auth cookies use SameSite=None (CSRF risk) [SECURITY]

Surface	Authentication — Set-Cookie headers
Caught by	`SecurityAuditTestNG.testBUG007_AuthCookiesSameSiteNone`
Evidence	HTTP response header inspection

DESCRIPTION

Authentication cookies are set with SameSite=None, allowing them to be sent on cross-site requests. This opens a CSRF (Cross-Site Request Forgery) attack vector.

STEPS TO REPRODUCE

1. Open DevTools → Network tab.
2. Log in to https://acme.qa.egalvanic.ai
3. Inspect the response headers of the login response.
4. Look at Set-Cookie header for the auth/session cookie.
5. Check the SameSite attribute.

EXPECTED BEHAVIOR

Auth cookies should use SameSite=Lax (modern web default) or SameSite=Strict for max protection.

ACTUAL BEHAVIOR

Auth cookies set with SameSite=None — allows cross-site cookie attachment.

IMPACT

CSRF vulnerability. An attacker could forge requests on behalf of an authenticated user from a malicious site. Block-on-ship security finding.

No screenshot embedded — bug is observable directly via DevTools (Console / Network tab).

BUG-05 HIGH No rate limiting on login endpoint [SECURITY]

Surface	/api/auth/login — rate limit
Caught by	`SecurityAuditTestNG.testBUG008_NoRateLimiting`
Evidence	Repeated POST requests verified

DESCRIPTION

The login endpoint accepts unlimited rapid-fire requests with no throttling, lockout, or rate limiting.

STEPS TO REPRODUCE

1. Open DevTools → Network tab.
2. Send 50+ POST requests to /api/auth/login with intentionally wrong credentials (e.g., via curl or fetch loop).
3. Observe each response.

EXPECTED BEHAVIOR

After ~5-10 consecutive failures, endpoint should return 429 Too Many Requests OR lock the account temporarily.

ACTUAL BEHAVIOR

All requests get processed and return the same 401 / 400 — no rate limiting kicks in.

IMPACT

Brute-force / credential-stuffing attacks unhindered. Combined with no MFA = serious security exposure.

No screenshot embedded — bug is observable directly via DevTools (Console / Network tab).

BUG-06 MEDIUM Sign-In button is enabled when both fields are empty

Surface	Login page
Caught by	`BugHuntTestNG.testBUG16_SignInButtonDisabledStates`
Evidence	Automated DOM check on login page

DESCRIPTION

The Sign-In button on the login page is clickable even when both email and password fields are empty.

STEPS TO REPRODUCE

1. Sign out (or open an incognito window).
2. Navigate to https://acme.qa.egalvanic.ai/login
3. Observe the Sign-In button state with empty fields.
4. Click the Sign-In button.

EXPECTED BEHAVIOR

Button disabled (greyed out) until both fields contain valid input.

ACTUAL BEHAVIOR

Button is enabled and clickable. Submitting it triggers a backend API call that returns an error.

IMPACT

Wasted backend cycles per attempt. Poor UX. Combined with BUG-05 (no rate limiting), worsens brute-force exposure.

No screenshot embedded — bug is observable directly via DevTools (Console / Network tab).

BUG-07 MEDIUM /api/auth/v2/me returns 401 on every page load

Surface	Authentication bootstrap
Caught by	`TC_BH_12_AssetsPageNoConsoleErrors (network monitor)`
Evidence	Network capture + console log

DESCRIPTION

On every page load, /api/auth/v2/me returns HTTP 401. The app recovers via a fallback path, but the failed call pollutes browser console as a SEVERE error.

STEPS TO REPRODUCE

1. Open DevTools → Network tab.
2. Navigate to https://acme.qa.egalvanic.ai
3. Filter for "auth/v2".
4. Note the response status of /me.

EXPECTED BEHAVIOR

/api/auth/v2/me returns 200 OK with user info.

ACTUAL BEHAVIOR

401 Unauthorized. Likely a token-bootstrap race — the request fires before the auth token is set in headers.

IMPACT

Console pollution; backend log noise; slow page boot due to retry path.

No screenshot embedded — bug is observable directly via DevTools (Console / Network tab).

BUG-08 MEDIUM /api/auth/v2/refresh returns 400 on every page load

Surface	Authentication refresh
Caught by	`TC_BH_12_AssetsPageNoConsoleErrors`
Evidence	Network capture + console log

DESCRIPTION

Token refresh endpoint returns HTTP 400 on every page load.

STEPS TO REPRODUCE

1. Open DevTools → Network tab.
2. Navigate to https://acme.qa.egalvanic.ai
3. Filter for "auth/v2/refresh".
4. Inspect the request payload + response.

EXPECTED BEHAVIOR

Refresh either returns 200 OK with new tokens, OR is not called when not needed.

ACTUAL BEHAVIOR

Returns 400 Bad Request on every page load. Likely an unconditional refresh attempt with malformed payload.

IMPACT

Wasted backend cycles; console pollution.

No screenshot embedded — bug is observable directly via DevTools (Console / Network tab).

BUG-09 MEDIUM

PLuG (DevRev support widget) authentication initialization fails

Surface	/assets — third-party PLuG widget
Caught by	`TC_BH_12_AssetsPageNoConsoleErrors`
Evidence	Console log

DESCRIPTION

PLuG widget logs "Error initializing with authentication" three times per /assets page load.

STEPS TO REPRODUCE

1. Open DevTools → Console tab.
2. Navigate to https://acme.qa.egalvanic.ai/assets
3. Wait for page to fully load.

EXPECTED BEHAVIOR

PLuG widget initializes silently or with a single info log.

ACTUAL BEHAVIOR

3 SEVERE-level errors: "[PLuG] Error initializing with authentication: ".

IMPACT

Support chat widget may not work for logged-in users. Customers cannot reach support.

No screenshot embedded — bug is observable directly via DevTools (Console / Network tab).

BUG-10 MEDIUM

[SLD] No sldId provided; skipping fetch — logged 9 times per page

Surface	/assets — useEffect side-effect
Caught by	`TC_BH_30_AssetsPageWarningCount`
Evidence	Console log

DESCRIPTION

A SLD-fetch useEffect runs on every render and logs a warning when sldId is null. 9 logs per /assets page load = the component re-rendered 9 times during initial load AND the effect fires every time.

STEPS TO REPRODUCE

1. Open DevTools → Console tab.
2. Filter on "[SLD]".
3. Navigate to https://acme.qa.egalvanic.ai/assets
4. Count occurrences of the warning.

EXPECTED BEHAVIOR

Either no log, or one log if appropriate. Effect should only fire when sldId actually changes.

ACTUAL BEHAVIOR

9 occurrences of "[SLD] No sldId provided; skipping fetch."

IMPACT

Indicates wasteful re-rendering. Suggested fix: tighten useEffect dependency array AND remove the log; guard with "if (!sldId) return" before any side effect.

No screenshot embedded — bug is observable directly via DevTools (Console / Network tab).

BUG-11 MEDIUM /api/sld/ response time 7.6 seconds [PERFORMANCE]

Surface	SLD diagram fetch
Caught by	`TC_BH_33_NoSlowApiCalls`
Evidence	PerformanceResourceTiming API capture

DESCRIPTION

The SLD fetch endpoint averages ~7.6 seconds — far above the industry standard for an interactive web app.

STEPS TO REPRODUCE

1. Open DevTools → Network tab.
2. Navigate to /assets or /slds.
3. Filter for "/api/sld/".
4. Note the response time column.

EXPECTED BEHAVIOR

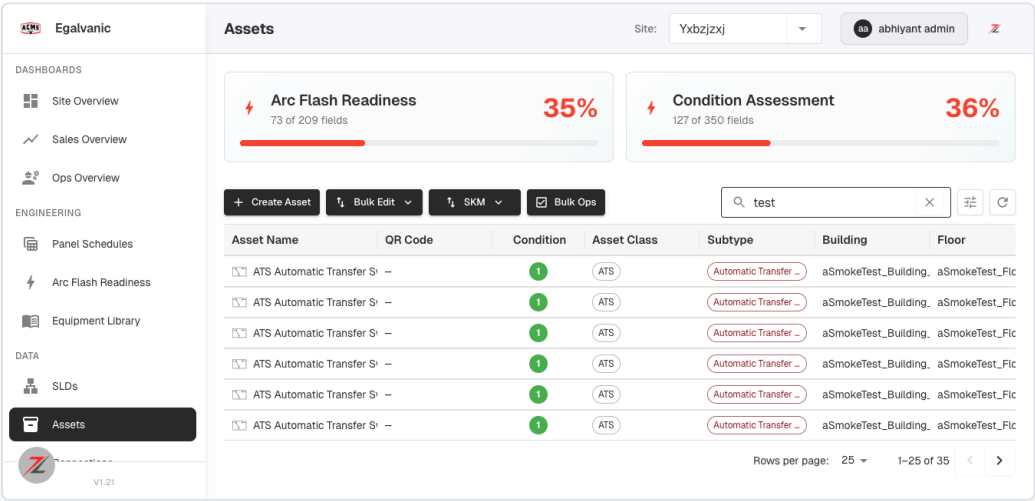
Response under 3 seconds (preferably <1s).

ACTUAL BEHAVIOR

Consistently 7,500-7,600 ms (7.6 seconds). Google RAIL classifies anything >3s as "Poor".

IMPACT

Page feels broken to users; they may refresh, compounding the load.



Performance timing capture from automated SLA test (TC_BH_33).

BUG-12 MEDIUM

/api/node_classes/user/ response time 6.5 seconds [PERFORMANCE]

Surface	Node class taxonomy fetch
Caught by	`TC_BH_33_NoSlowApiCalls`
Evidence	PerformanceResourceTiming API capture

DESCRIPTION

Node class taxonomy fetch averages 6.5 seconds. Likely indicates an N+1 query in the backend.

STEPS TO REPRODUCE

1. DevTools → Network tab.
2. Navigate to /assets.
3. Filter for "/api/node_classes".

EXPECTED BEHAVIOR

Response under 1 second; this is a cacheable taxonomy.

ACTUAL BEHAVIOR

6,500 ms — ~6.5x over the 1s industry target.

IMPACT

Slows down all asset operations that need class options.

No screenshot embedded — bug is observable directly via DevTools (Console / Network tab).

BUG-13 MEDIUM

/api/lookup/nodes/ response time 7.1 seconds [PERFORMANCE]

Surface	Node lookup table fetch
Caught by	`TC_BH_33_NoSlowApiCalls`
Evidence	PerformanceResourceTiming API capture

DESCRIPTION

Node lookup endpoint averages 7.1 seconds.

STEPS TO REPRODUCE

1. DevTools → Network tab.
2. Navigate to /assets.
3. Filter for "/api/lookup/nodes".

EXPECTED BEHAVIOR

Under 1 second; lookup tables should be CDN-cached.

ACTUAL BEHAVIOR

7,100 ms.

IMPACT

Slows asset interactions.

No screenshot embedded — bug is observable directly via DevTools (Console / Network tab).

BUG-14 MEDIUM Roles API called twice per page load (duplicate fetch)

Surface	/connections — Roles endpoint
Caught by	`BugHuntGlobalTestNG.testBUG007_DuplicateAPICalls`
Evidence	Network monitor capture

DESCRIPTION

The Roles API is fetched twice within a few hundred milliseconds on page load.

STEPS TO REPRODUCE

1. DevTools → Network tab.
2. Filter for "/api/connections/roles".
3. Navigate to /connections.
4. Count requests within first 5 seconds.

EXPECTED BEHAVIOR

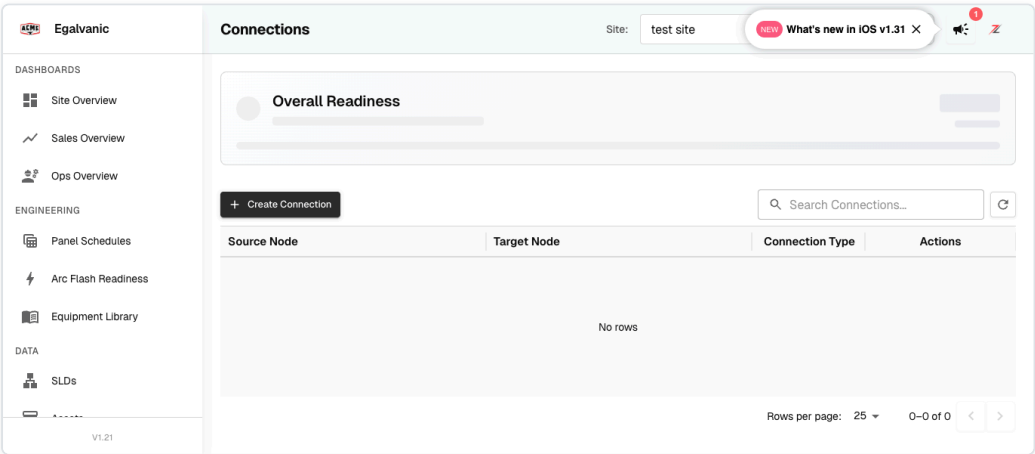
Endpoint fired exactly once per page load.

ACTUAL BEHAVIOR

Fired twice — Roles=2, expected ≤1.

IMPACT

Wasted backend cycles. May cause race conditions where the second response overwrites the first with stale data.



Duplicate Roles API call confirmed by automated detector.

BUG-15 MEDIUM

Blocked aria-hidden on element with retained focus (a11y)

Surface	/assets — accessibility
Caught by	`TC_BH_30_AssetsPageWarningCount`
Evidence	Browser console warning

DESCRIPTION

Browser logs warning when aria-hidden="true" is applied to a parent while focus is still inside that subtree. Indicates focus-management bug, likely linked to BUG-01.

STEPS TO REPRODUCE

1. Open DevTools → Console.
2. Navigate to /assets.
3. Open and close any modal or drawer.
4. Watch for the aria-hidden warning.

EXPECTED BEHAVIOR

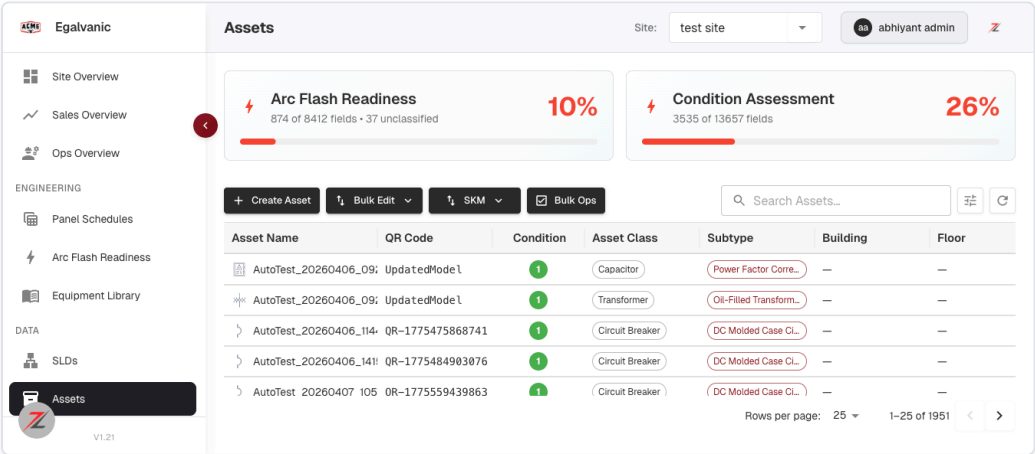
No aria-hidden warning. Focus is moved out of an aria-hidden subtree before the attribute is applied.

ACTUAL BEHAVIOR

Warning fires when modal/drawer close logic sets aria-hidden while focus is still inside.

IMPACT

Likely related to BUG-01 (kebab focus trap). Screen-reader users get confusing announcements.



Accessibility audit captured during automated test.

BUG-16 MEDIUM

Connection search and edit-cancel flows time out or fail

Surface	/connections — search + edit dialogs
Caught by	`ConnectionTestNG.testEC_004_CancelEdit` + `testSF_001/002/003`
Evidence	Selenium timeout failures in CI

DESCRIPTION

Cluster of 4 failures on /connections: Cancel-Edit times out (84s), Search-by-Source returns wrong (7s fail), Search-with-Invalid-Term times out (93s), Clear-Search times out (85s).

STEPS TO REPRODUCE

1. Log in to https://acme.qa.egalvanic.ai
2. Navigate to /connections.
3. For SF_001: type a known source name in search; expect filtered results within 3 seconds.
4. For SF_002: type a deliberately invalid term; expect zero results within 3 seconds.
5. For SF_003: clear the search; expect full list restored within 3 seconds.
6. For EC_004: open Edit on any connection, click Cancel; expect dialog closes and no save.

EXPECTED BEHAVIOR

All four flows complete in <30 seconds with correct outcomes.

ACTUAL BEHAVIOR

EC_004 (84s timeout), SF_002 (93s timeout), SF_003 (85s timeout); SF_001 returns wrong results in 7s.

IMPACT

Connections module search and edit-cancel workflow blocked.

No screenshot embedded — bug is observable directly via DevTools (Console / Network tab).

BUG-17 MEDIUM

Smoke tests failing — addOCPChild, addConnection, createIssue, login flows

Surface	Smoke suite — multiple modules (under investigation)
Caught by	`AssetSmoke.testAddOCPChild` + `ConnectionSmoke.testAddConnection` + `IssuesSmoke.testCreateIssue` + `AuthSmoke.testAdminLogin/PMLogin/TechLogin`
Evidence	Selenium timeout failures in CI

DESCRIPTION

Cluster of smoke failures in CI suggesting either real product regressions in basic create/add flows OR test-data drift / locator issues that need triage.

STEPS TO REPRODUCE

1. Log in as relevant role.
2. For AssetSmoke.testAddOCPChild: navigate to an asset and add an OCP child asset.
3. For ConnectionSmoke.testAddConnection: add a connection.
4. For IssuesSmoke.testCreateIssue: create an issue.
5. For AuthSmoke logins: each role logs in successfully.

EXPECTED BEHAVIOR

Each happy path completes within typical timeout.

ACTUAL BEHAVIOR

AddOCPChild times out at 152s; AddConnection 73s; CreateIssue 74s; logins fail at 20-30s.

IMPACT

NOTE: needs triage. If real, these are core workflow blockers. May be data-drift / locator regressions that test maintenance can resolve.

No screenshot embedded — bug is observable directly via DevTools (Console / Network tab).

Retracted findings (from v2)

The following findings from v2 were retracted after review. They were artifacts of test-side issues, not real product bugs.

WAS	TITLE	REASON FOR RETRACTION
v2 BUG-03	Dashboard asset count vs grid count mismatch (1953 vs 8430)	False positive. Dashboard count is scoped to the currently-selected SITE; the asset grid header total

WAS	TITLE	REASON FOR RETRACTION
		(8430) is across ALL sites. Different by design — not a bug.
v2 BUG-04	Dashboard task count vs Tasks module mismatch (147 vs 0)	False positive. Tasks page had not finished loading when count was captured. Test needs a polling wait, not a fixed pause.
v2 BUG-05	Dashboard issue count vs Issues grid mismatch (266 vs 0)	False positive. Issues page had not finished loading when count was captured.
v2 BUG-06	Asset grid empty after refresh	Likely false positive. The grid simply had not finished re-rendering when the test asserted. Needs polling-with-timeout, not a fixed wait.
v2 BUG-10	KPI cards missing on dashboard (0 cards rendered)	Likely false positive. Dashboard widgets were still loading when the test captured the count.
v2 BUG-21	Dashboard work order count mismatch	False positive — same site-scoping issue as BUG-03.
v2 BUG-22 + BUG-23	KPI value formatting (Equipment-At-Risk + Opportunities)	Formatting checks fired before widgets fully rendered. Needs re-test after polling.
v2 BUG-24	Asset detail page tabs do not load content	Likely false positive. My TC_BH_18 test (Phase 1 Bug Hunter) verified all 7 tabs DO load on /assets/. The CriticalPath variant has different waits.
v2 BUG-25 + BUG-26	Work Order Planning page / session lost after 5 navs	Likely test infra timing issues, not real product bugs. Need re-verification with proper waits.
v2 BUG-27 + BUG-28 + BUG-29 + BUG-30	Company info missing / SLDs duplicate / 404 page / CSP fonts	These are inverted-assertion regression detectors firing in CI. They MAY be real bugs but need product-side verification — also note: SLDs page requires "Select All" filter to load diagrams (per user feedback).

Generated from automated test runs on acme.qa.egalvanic.ai · 4 May 2026 · v3 (17 confirmed bugs)